

Information Security Policy

Enterprise information-security framework for MedCore systems, users and data

Document ID	MC-IT-001
Version	3.0
Effective Date	01 September 2026
Review Cycle	Annual
Classification	Internal — Confidential

1. Purpose and Security Principles

MedCore protects information systems and data against unauthorized access, misuse, loss, disruption and inappropriate disclosure while maintaining availability for patient care and essential operations.

Security controls are based on risk, least privilege, defense in depth, secure configuration, accountability and timely response.

2. Scope

This policy applies to employees, clinicians, contractors, trainees, vendors and other authorized users of MedCore information systems, networks, endpoints, applications, cloud services and information assets.

3. Information and Asset Classification

Class	Examples	Minimum handling
Restricted	Patient records, credentials, security logs, sensitive investigations	Strong access control; approved systems; monitored handling
Confidential	HR, contracts, internal financial or operational data	Need-to-know access; controlled sharing
Internal	Procedures, internal communications, routine operational data	Internal distribution; approved storage
Public	Approved public information	May be distributed externally in approved form

4. Identity and Access Management

Every user must have an individual account where technically feasible. Shared credentials are prohibited except for formally approved technical exceptions.

Access is granted according to role and business need, reviewed periodically and removed when no longer required.

Privileged access must be restricted, monitored and used only for authorized administrative activities.

5. Authentication and Credential Security

Passwords and authentication factors must be protected from disclosure. Credentials must not be stored in plain text, shared through informal channels or reused across unrelated systems where stronger controls are available.

Multi-factor authentication should be used for privileged, remote and other high-risk access according to system capability and risk.

6. Endpoint, Network and System Security

Managed endpoints should use supported operating systems, security controls and approved configurations. Security updates must be applied according to risk and maintenance requirements.

Network segmentation, firewalling, monitoring and secure remote-access controls should be used to reduce unauthorized lateral movement and exposure.

Unapproved software, unauthorized devices and unapproved remote-access tools must not be introduced into the MedCore environment.

7. Data Protection

Restricted information should be encrypted in transit and, where appropriate, at rest. Transfers must use approved channels.

Backups of critical systems must be protected against unauthorized access and tested according to the applicable recovery requirements.

8. Security Monitoring and Logging

Systems should generate appropriate audit records for authentication, privileged activity, material changes and security events. Logs must be protected from unauthorized modification and retained according to the applicable schedule.

Security monitoring may identify unusual access, repeated authentication failures, malware indicators, data-transfer anomalies and other risk signals.

9. Third-Party and Cloud Security

Third parties with access to MedCore systems or sensitive information are subject to risk-based due diligence and contractual controls. Security and privacy requirements should be defined before access is enabled.

Cloud services must be approved through the applicable technology, procurement, security and privacy review process.

10. Incident Reporting

Suspected phishing, malware, credential compromise, unauthorized access, data exposure, lost devices or other security incidents must be reported promptly through the approved incident channel.

Users should not independently erase evidence, investigate beyond their role or communicate externally about a security incident unless authorized.

11. Business Continuity and Recovery

Critical technology services should have documented recovery priorities, backup arrangements and recovery procedures appropriate to their operational impact.

Recovery exercises and restoration tests should be performed periodically for systems designated as critical.

12. Security Awareness and Review

Users receive security awareness appropriate to their role. High-risk technical and administrative roles may require additional training.

This policy is reviewed at least annually and after significant changes to systems, threat exposure, organizational responsibilities or regulatory requirements.

Frequently Asked Questions

Can I use a personal USB drive for hospital files?

Not unless the device and use have been explicitly approved. Use MedCore-managed storage and transfer methods.

What should I do with a suspicious email?

Do not open unexpected links or attachments. Use the approved reporting mechanism and follow IT Security instructions.

Is a strong password enough for privileged access?

Password strength is only one control. Privileged access should use appropriate authentication, restricted permissions and monitoring.